

1. Overview of PCI DSS 4.0

- **Introduction to PCI DSS:**
 - Evolution of the Payment Card Industry Data Security Standard
 - Key changes in version 4.0
 - Purpose and scope of PCI DSS
- **Importance in the Context of CISM:**
 - How PCI DSS aligns with the CISM focus on Information Security Management
 - Compliance as part of enterprise governance and risk management

2. PCI DSS Core Principles and Objectives

- **12 Core Requirements:**
 - Build and Maintain a Secure Network and Systems
 - Protect Cardholder Data
 - Maintain a Vulnerability Management Program
 - Implement Strong Access Control Measures
 - Regularly Monitor and Test Networks
 - Maintain an Information Security Policy
- **Relation to CISM Domains:**
 - Mapping PCI DSS requirements to CISM domains of risk management, incident response, governance, and more.

3. Control Objectives and Key Changes in PCI DSS 4.0

- **Risk-based Approach:**
 - Shift to a more flexible, risk-based approach in security measures.
 - Customizing security controls based on risk levels.
- **Validation and Monitoring:**
 - Real-time monitoring, testing, and validation of security controls.
- **Enhanced Authentication:**
 - Stronger emphasis on multi-factor authentication (MFA) and other authentication technologies.
- **Changes in Encryption:**
 - Advancements and stricter encryption requirements.

4. Governance and Risk Management in PCI DSS 4.0

- **Governance Requirements:**

- PCI DSS governance structure and its relevance to CISM's governance framework.
- **Risk Management Approaches:**
 - Identifying and evaluating risks related to payment card data
 - How to integrate risk assessment in alignment with PCI DSS controls.
 - Implementing risk mitigation and continuous monitoring for compliance.
- **Policy Development:**
 - Crafting security policies that reflect PCI DSS controls and ensure enterprise-wide adherence.

5. PCI DSS Compliance Lifecycle

- **PCI DSS Readiness Assessment:**
 - Initial risk assessments, gap analysis, and defining security objectives.
- **Implementation of Security Controls:**
 - Applying the necessary controls for data protection, network security, access control, and logging.
- **Continuous Compliance Monitoring:**
 - How PCI DSS compliance demands regular assessments, audit preparation, and remediation.
- **Maintaining and Reporting Compliance:**
 - Documentation requirements for audits, incident reporting, and audit response strategies.

6. Specific PCI DSS 4.0 Security Controls

- **Encryption Standards:**
 - PCI DSS encryption guidelines for cardholder data, ensuring data is encrypted at rest and in transit.
- **Data Retention and Disposal:**
 - Policies for the retention, deletion, and secure disposal of cardholder data.
- **Access Control Measures:**
 - Role-based access control (RBAC) and least privilege principles.
- **Incident Response:**
 - PCI DSS-aligned incident response strategies for payment card data breaches.

7. Vendor and Third-Party Management

- **Third-Party Risk Management:**
 - Managing PCI DSS compliance through third-party vendors and service providers.

- Contractual agreements, due diligence, and vendor compliance monitoring.
- **Auditing and Assessment of Third Parties:**
 - Ensuring third-party providers adhere to PCI DSS controls.

8. Key Tools and Techniques for PCI DSS Compliance

- **Security Information and Event Management (SIEM):**
 - Using SIEM solutions to automate monitoring and ensure timely detection of security incidents.
- **Vulnerability Management and Patch Management:**
 - Regular scanning for vulnerabilities and ensuring patches are applied within required timelines.
- **Penetration Testing:**
 - Required penetration testing guidelines under PCI DSS 4.0.

9. Documentation and Audit Evidence for PCI DSS

- **Compliance Reporting:**
 - Documentation required for Qualified Security Assessors (QSA) and Self-Assessment Questionnaires (SAQ).
- **Audit Preparation:**
 - Building an audit evidence repository, policies, procedures, and risk assessment documentation.

10. Case Studies and Practical Applications

- **Real-world Use Cases:**
 - Examples of enterprises implementing PCI DSS successfully.
 - Common compliance challenges and solutions.
- **Scenario-based Exercises:**
 - Risk management, incident response, and control implementation exercises tied to CISM learning objectives.

11. Mapping PCI DSS to CISM Domains

- **Information Security Governance:**
 - How PCI DSS requirements contribute to an organization's governance objectives.
- **Information Risk Management:**
 - Identifying and managing risk in compliance with PCI DSS.
- **Information Security Program Development and Management:**

- Developing security programs that comply with both CISM and PCI DSS requirements.
- **Incident Management:**
 - Incident response strategies that meet PCI DSS 4.0 requirements and CISM expectations.

12. Continuous Improvement and Future Trends

- **Anticipating Changes in PCI DSS:**
 - Preparing for future updates and evolving compliance requirements.
- **Emerging Threats to Payment Security:**
 - Keeping updated on the evolving threat landscape and adapting controls accordingly.

This comprehensive approach-based training document provides both theoretical and practical insights. The document should cover detailed examples, best practices, and exercises to solidify learning. You can also integrate flowcharts, checklists, and scenario-based questions to enhance understanding.